

단 3일, 2.8억 원의 비용 폭탄을 막아낸 SIEM Bot Monitor

BOT 대응을 탐지·승인·배포·검증·복구가 이어지는 운영 시스템으로 바꾼 과정

트로이전쟁 수준의 봇과의 전쟁

Akamai

CDN + Security 주력
WAF · Bot Manager

AWS 로그

서비스 인프라 로그

Dynatrace

APM 관측

사람

여러 화면을 오가며 수동으로 추적 · 예방 · Mitigation

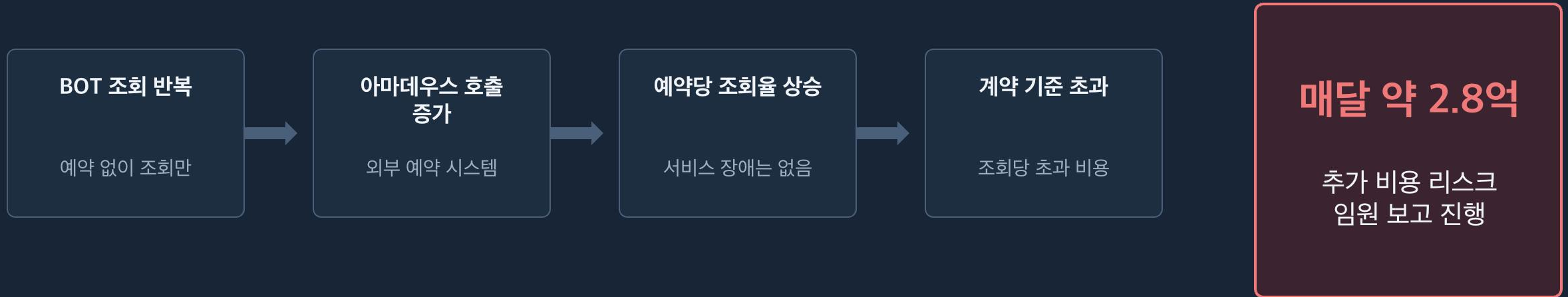
대고객 서비스(홈페이지·앱)를 지키는 봇 대응은 데브옵스의 오래된 일상 업무였다

트로이전쟁 수준의 봇과의 전쟁



새벽 2시에 못 자는 이유 — 인터넷에서 봇이 나쁜 짓을 하고 있음

2026년 4월, 대응할 수 없는 수준의 공격



기존 방식으로는 불가 → 금요일 저녁부터 3일, 심심이(SIEM Bot Monitor) 구축

수동 대응의 한계



30분+

건별 최소 소요

오탐·미탐 확인까지 매번 반복

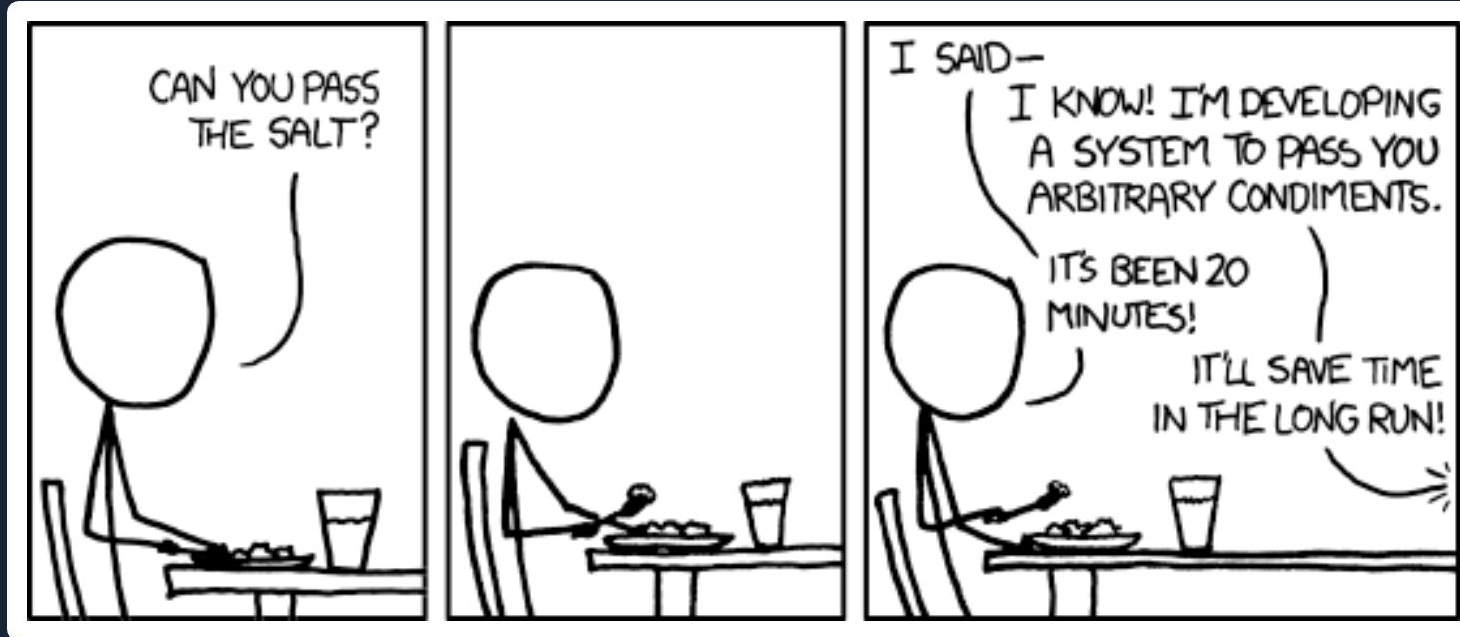
공격자는 차단을 감지하면 곧바로 식별값·Request 특성을 바꿔 재공격

가장 문제가 되는 시간대는 저녁·야간 — 판단할 수 없거나, 성급하게 차단하거나

Rule 생성기가 아니라 운영 루프



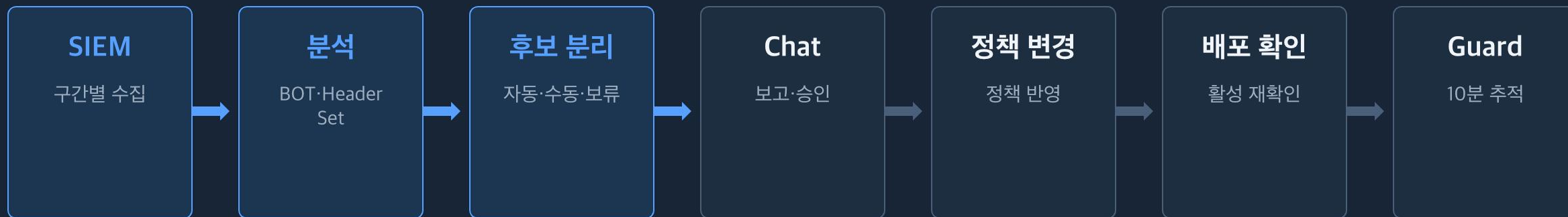
Rule 생성기가 아니라 운영 루프



“소금 좀 건네줘” → “임의의 조미료를 전달하는 시스템을 개발 중이야”

…ChatOps 하나 만들려다 운영 루프가 나온 사람의 변명입니다

전체 흐름 한 장

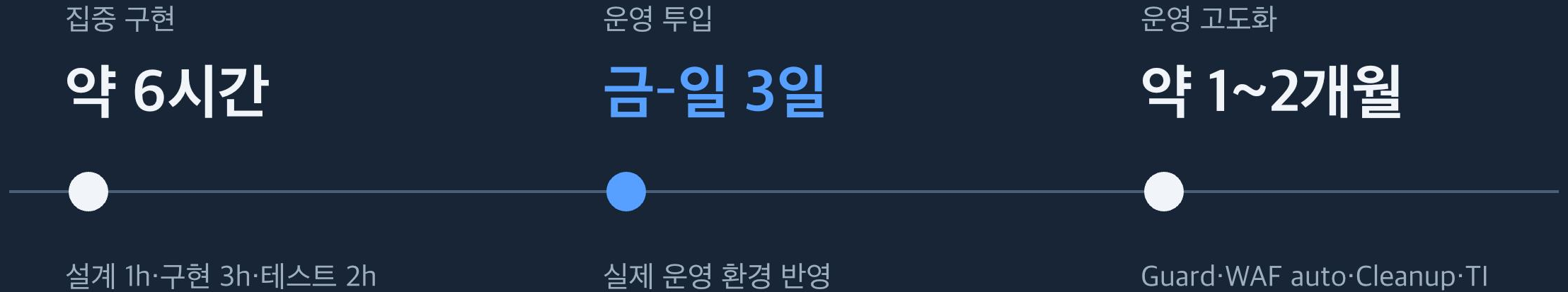


자동 분석·분류

사전 기준 충족 또는 사람 승인 뒤에만 실행

이상 징후 → 롤백 권고 · 최종 결정은 Chat에서 사람이

6시간, 3일, 그리고 지금까지



수동 대응 경험이었기에 가능했던 속도 · 현재 약 3개월째 정상 운영 중

오탐 자동화가 되지 않게

자동 조치

핵심 신호 중첩 확인
기존 정책 미포함
정상 사용자 가능성 낮음

실행 가능

사람 검토

신호는 겹치지만
확실함이 부족

승인 필요

관측 전용

오탐 리스크가 큰
로그인·좌석·결제

차단 배제

보류

데이터 불완전
근거 부족

재분석

전부 자동 차단하면 운영 자동화가 아니라 오탐 자동화가 된다

후보는 어떤 신호를 조합했나

식별

반복되는 군집·지문

행동

요청 패턴·클라이언트
특성

맥락

대상 API·정상 사용자
피해

기존 방어

이미 커버되는지·정책
충돌

단일 ID·score·외부 평판만으로 자동 차단하지 않는다

정확한 임계값과 필드 조합은 공개 범위에서 제외

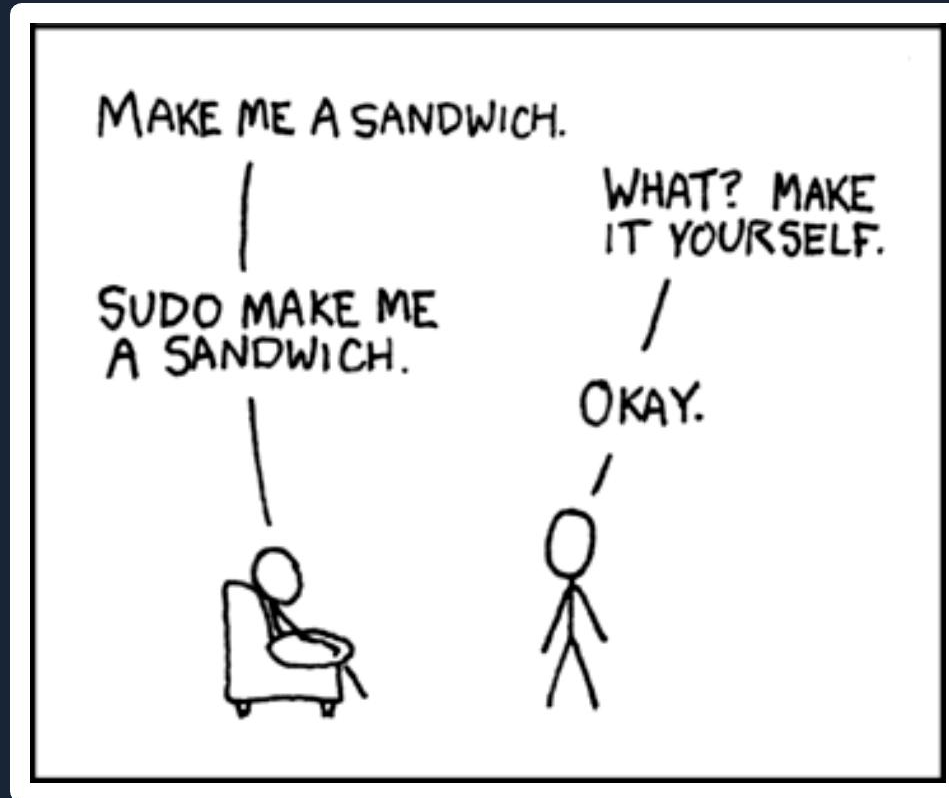
승인 뒤에도 확인한다



성공도 실패도 추측하지 않는다

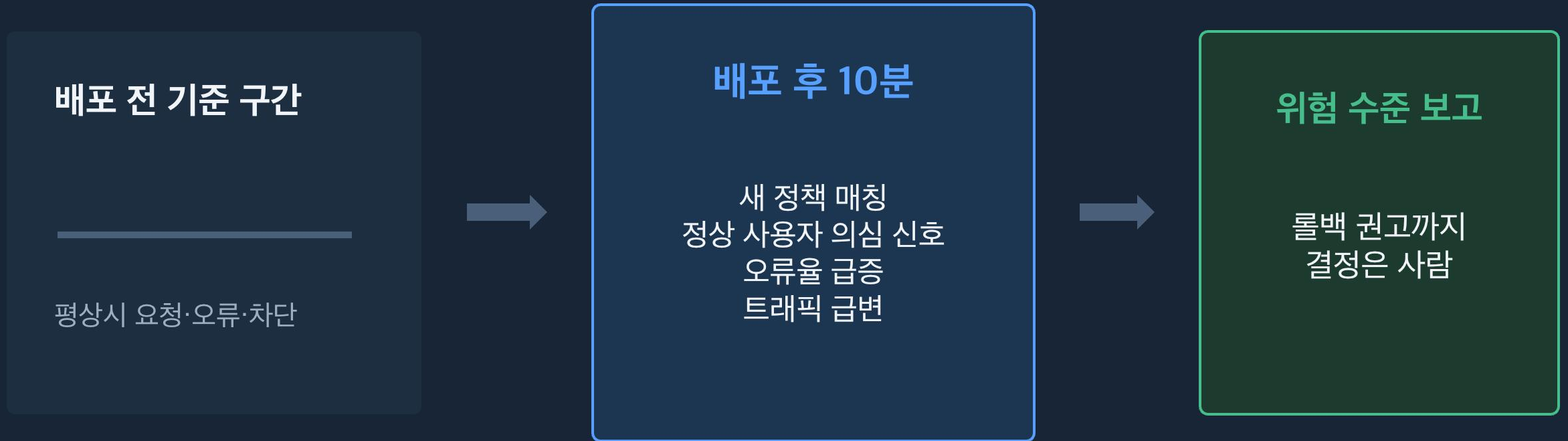
timeout은 실패가 아니라 결과를 모르는 상태 — 재조회 전에는 아무것도 재실행하지 않음

승인 뒤에도 확인한다

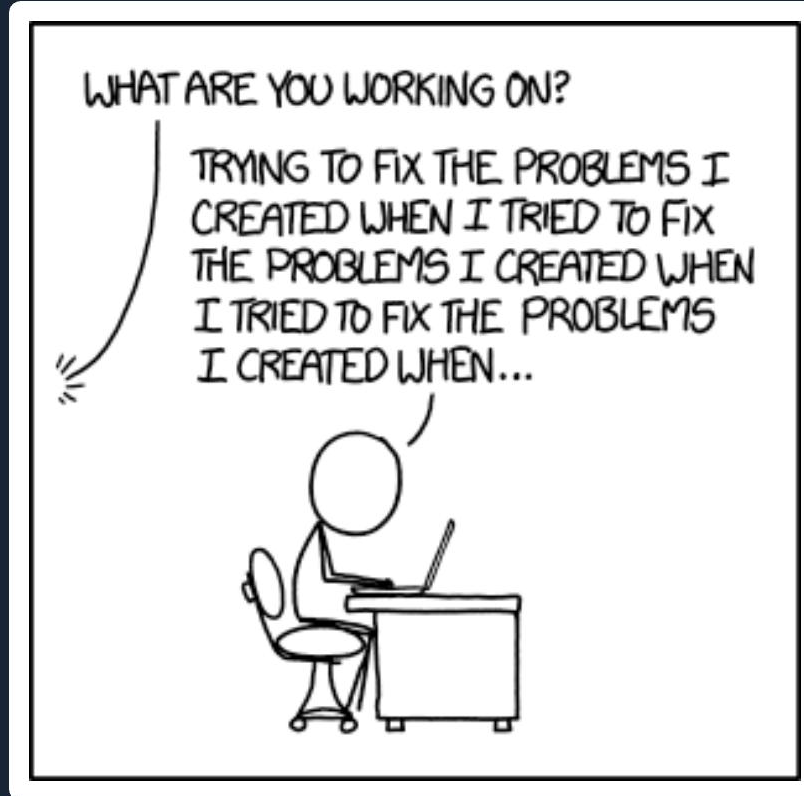


“배포해줘” → 거부 · “sudo 배포해줘(승인)” → 그래도 적용 직전에 한 번 더 검증

Guard — 차단량이 아니라 정상 사용자를 본다



Guard — 차단량이 아니라 정상 사용자를 본다



자동 롤백까지 만들면... 자동 롤백을 감시할 Guard의 Guard가 필요해진다

운영이 가르쳐준 안전장치

여러 루프의 동시 배포 충돌



전체 설정 변경을 하나의 lock으로

재시작이 분석·Guard를 끊음



안전 재시작 — 진행 중 작업 확인·대기
상태 저장으로 Guard 재개

오탐 대가가 큰 API



관측·학습 전용으로만 반영

일부는 미리 설계했지만, 상당수는 실제 이슈를 겪으며 계속 보강한 것들이다

AI의 역할과 경계

AI Agent

Kiro · Claude · Codex

1. 생소한 API 탐색
2. SIEM 응답 구조 분석
3. 설계 → 구축 → 테스트 반복

속도를 높인다

사람

1. 어떤 신호를 공격으로 볼지
2. 정상 사용자 피해 판단
3. 배포·롤백 결정

판단과 통제권을 가진다

성과

약 2.8억

30분
→ 2분

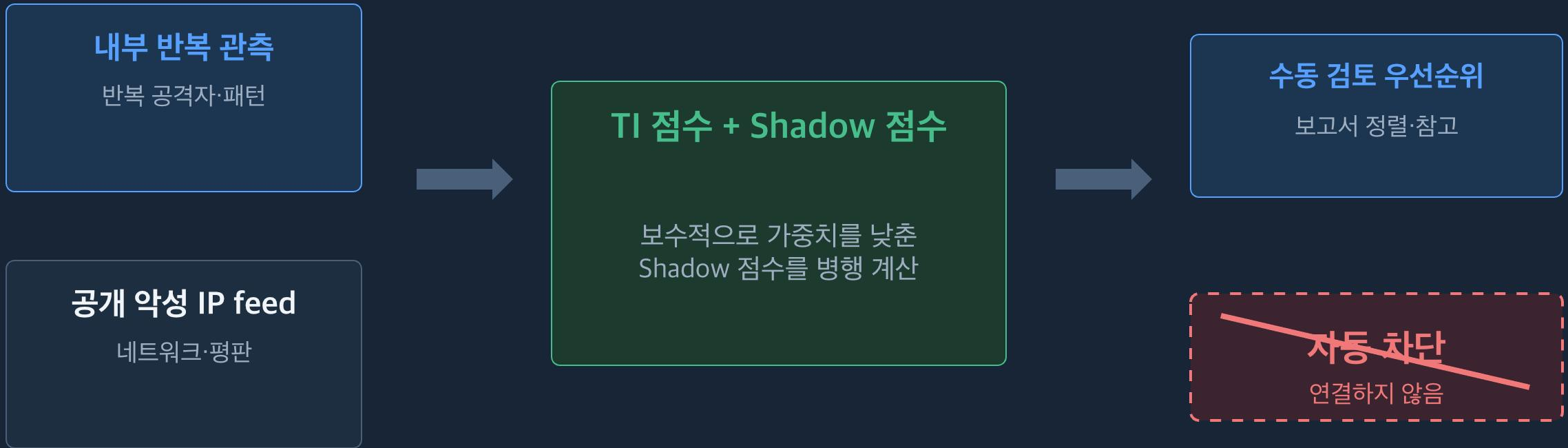
업무시간
→ 24h

기준 대비
<30%

5년 수동 배포 약 600건 ↔ 심심이 3개월 800건+

예약당 외부 조회 비율은 지금도 심심이가 최저치를 갱신 중

Threat Intelligence는 참고, 차단은 아니다



외부 정보는 오래됐거나 우리 환경에선 오탐일 수 있다 — 우선순위 참고까지만

주간 개선 루프



제안은 자동, 결정은 사람

만드는 것뿐 아니라 개선 사이클에도 AI를 쓰지만, 원칙은 동일하다

세 가지 정리

- 1 보안 이벤트 + (서비스 히스토리 + 비즈니스) = 성과
- 2 수동 대응 → 자동화 = 24시간 · 2분 내외 · 2.8억의 성과
- 3 AI의 가치는 운영 자체를 위임 X
→ 가설 검증과 실패의 속도를 높여, 더 중요한 판단에 집중하게 하는 것

긴 발표 들어주셔서 감사합니다

박준형 · Homepage DevOps / Starlink TF TPM



LinkedIn

linkedin.com/in/jun10920



개발 블로그

jun10920.tistory.com

2.8억 원은 어떻게 계산했나

$$\begin{array}{ccc} \begin{array}{c} \text{예상 외부 조회량} \\ \text{공격 흐름이 유지될 경우} \end{array} & - & \begin{array}{c} \text{계약 허용량} \\ \text{기준값 비공개} \end{array} \\ & & = \\ & & \begin{array}{c} \text{초과 조회량} \\ \times \text{계약 단가} \end{array} \end{array}$$

이미 청구된 비용이 아니라 방치 시 매달 발생할 수 있었던 추가 비용 리스크

실제 기준선·단가·내부 비율은 공개하지 않는다

왜 Lambda가 아니라 EC2였나

Lambda

SIEM 수집이 분 단위
승인 대기 상태 유지 필요

컨테이너

사흘짜리 POC에는
셋업이 과함

최소 EC2

월 \$10 · 상시 구동
빠른 구축과 디버깅

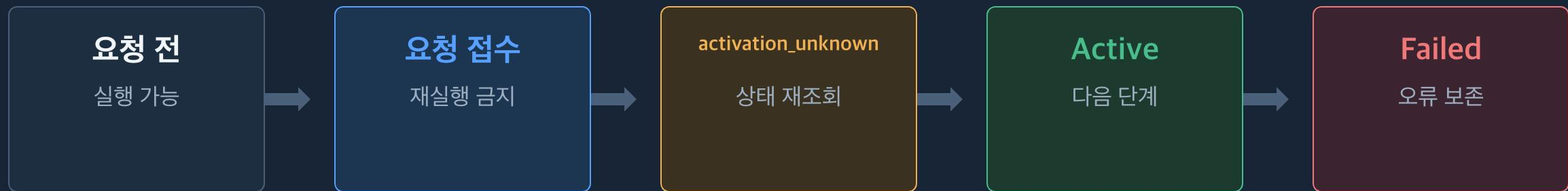
급한 상황의 최소 비용·최소 시간 선택 — 최종 확장 구조의 정답은 아니다

작은 인스턴스로 시간당 10만 건 처리



서버를 키우기 전에 처리 방식을 바꿨다

배포 상태는 어떻게 복구했나



timeout 뒤 재시도하지 않고 실제 상태를 확인한다

부분 반영은 같은 draft와 누락 항목을 검증한 뒤 이어서 처리

Guard는 무엇을 비교했나



새 정책 매칭



정상 사용자 의심



오류율



전체 차단률



대상 트래픽

SIEM 지연과 일시 변동 때문에 자동 rollback하지 않는다

Guard는 위험을 설명하고 사람이 결정한다

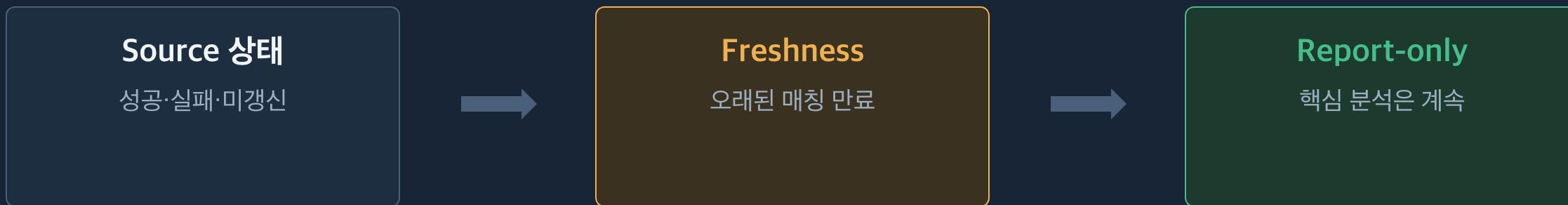
안전 재시작은 어떻게 동작하나



상태 파일 + 백업 2세대 보존 — 재시작이 진행 중인 작업을 삼키지 않는다

배포도 직접 restart 대신 안전 재시작 절차만 사용

외부 TI가 오래되거나 실패하면



외부 source 하나의 실패나 오래된 IOC가 운영 실행을 결정하지 않는다

내부 반복 관측과 함께 후보 설명에만 사용

테스트가 보장하는 것과 보장하지 않는 것

검증됨

- 상태·backup
- 명령 안전성
- timeout·activation
- Guard·관측 전용 경계
- TI cache·store

미검증 또는 실패

- live Akamai
- live EC2·API Gateway
- 실제 Google Chat
- 일부 SIEM replay
- 현재 타입 검사 clean

403 passed · 4 skipped · 15 type errors (2026-08-17 재실행)

AI와 회사 데이터의 경계

사용

API 문서
비식별 구조
합성 이벤트
테스트·코드 review

제외

자격 증명
raw 고객 데이터
내부 URL·식별자
실제 운영 화면

운영 runtime과 LLM은 분리돼 있다

다시 만든다면

현재

큰 단일 앱

로컬 state

shared secret

로컬 검증



다음 구조

분리된 worker-executor

durable queue·외부 store

operator identity·audit

고정 버전 CI·replay fixture

우선 수정: state와 backup이 모두 손상되면 앱 기동 자체를 중단

출처 · Credits

만화 — xkcd by Randall Munroe

xkcd #386	“Duty Calls”	트로이전쟁 장 뒤
xkcd #974	“The General Problem”	운영 루프 장 뒤
xkcd #149	“Sandwich”	승인 장 뒤
xkcd #1739	“Fixing Problems”	Guard 장 뒤

라이선스: CC BY-NC 2.5 · xkcd.com (비상업 커뮤니티 발표 사용)

정식 본편: SIEM-Bot-Monitor_AWSKRUG_v3.pdf · 전체 밈 버전: SIEM-Bot-Monitor_밈버전.pdf